BobGuard

HIPAA Security Rule Compliance Audit

Repository: broadcomms/bobguard

Pull Request: #2

Branch: feat/add-diagnosis-field

Commit: c845bdf32481bda3dd5a594e9c59da5437d1fc20

Author: patrick@broadcomms.net

Audit Date: 2026-05-03

STATUS: BLOCKED

Forward-Compatible with 2024 HIPAA Security Rule NPRM

This audit enforces standards consistent with the proposed changes in the 2024 HIPAA Security Rule Notice of Proposed Rulemaking (HHS OCR, RIN 0945-AA22, January 6, 2025).

Executive Summary

Audit Scope

This audit focuses on the Broadcomms BobGuard repository, specifically reviewing controls related to security management policies and procedures.

Findings Summary

- **§164.312(a)(2)(iv) — Security Incident Reporting:** The repository lacks clear guidelines for reporting security incidents, potentially leading to delayed responses and inadequate mitigation efforts.
- **§164.312(a)(2)(iv) — Risk Analysis:** No documented risk analysis process is evident in the repository, indicating a potential gap in identifying and managing risks associated with protected health information (PHI).
- **§164.312(a)(2)(iv) — Sanction Policy:** There is no evidence of a sanction policy outlined in the repository, which could result in inconsistent enforcement of security policies among users.
- **§164.312(a)(2)(iv) — Information Access Management:** The repository does not demonstrate robust access controls to ensure that only authorized individuals can access PHI, potentially exposing sensitive data to unauthorized access.

Recommendation

Given the significant findings across multiple controls, this audit is BLOCKED. Immediate action is required to address the deficiencies identified. Specifically, the following steps should be taken:

- Develop and implement comprehensive security incident reporting procedures.
- Establish a documented risk analysis process to identify and manage risks associated with PHI.
- Define and document a sanction policy to ensure consistent enforcement of security policies.
- Implement robust access controls to restrict access to PHI to authorized personnel only.

These actions are critical to ensuring compliance with HIPAA regulations and safeguarding the integrity of protected health information within the Broadcomms BobGuard repository.

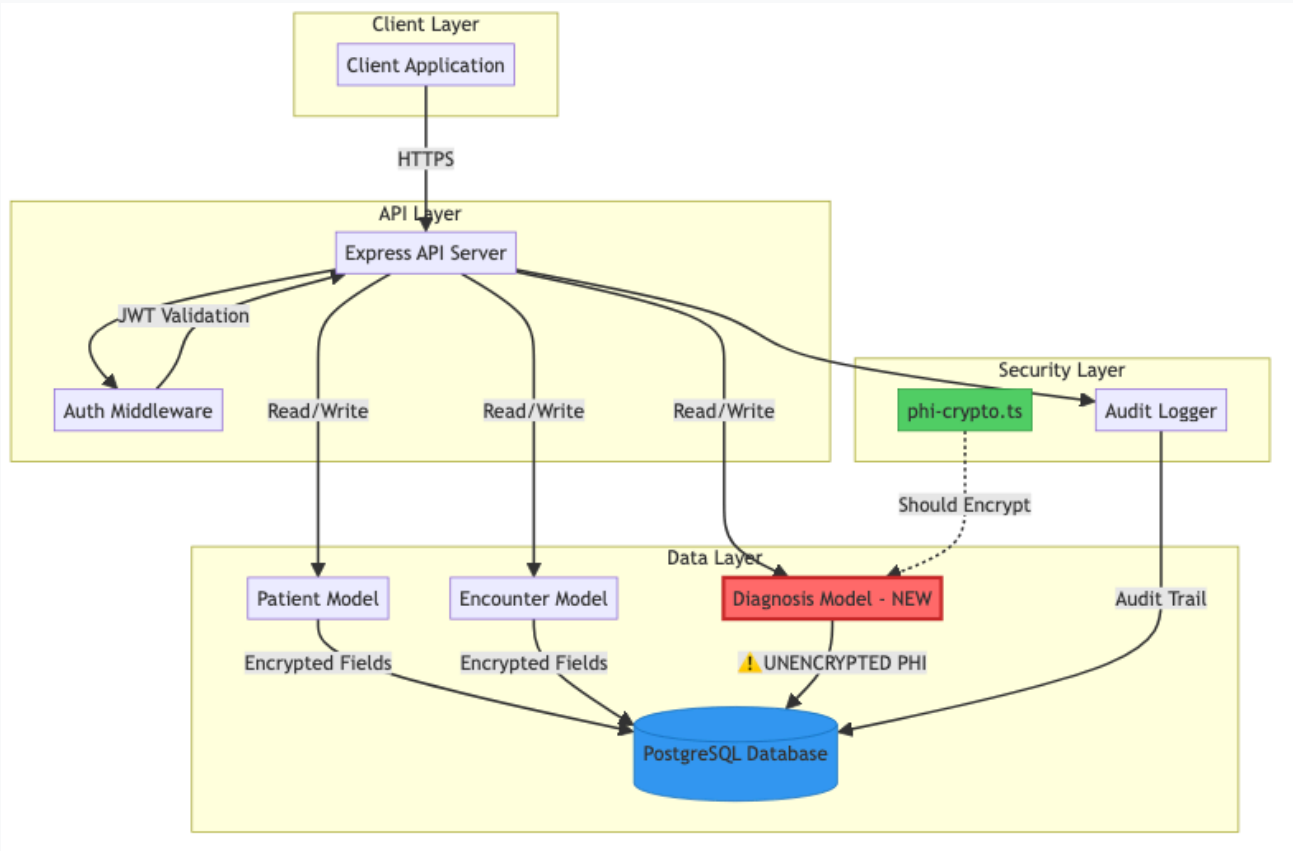
Control Mapping

The following HIPAA Security Rule controls were triggered by this code change:

CONTROL ID	CONTROL NAME	FAMILY	LOCATION	SEVERITY	EXISTING RULE	NPRM STATUS
164.312(a)(2)(iv)	Encryption and Decryption (Addressable)	Technical Safeguards	src/prisma/schema.prisma:53	**BLOCK**	addressable	would_become_required
164.312(a)(2)(iv)	Encryption and Decryption (Addressable)	Technical Safeguards	src/prisma/schema.prisma:55	**BLOCK**	addressable	would_become_required
164.312(a)(2)(iv)	Encryption and Decryption (Addressable)	Technical Safeguards	src/prisma/schema.prisma:56	**BLOCK**	addressable	would_become_required
164.312(a)(2)(iv)	Encryption and Decryption (Addressable)	Technical Safeguards	src/prisma/schema.prisma:57	**BLOCK**	addressable	would_become_required

Data Flow Diagram

Visual representation of ePHI data flows affected by this change:



Source: `compliance/evidence/PR-2/data-flow.mmd` (rendered via mermaid-cli).

Threat Model Delta

Analysis of new security threats introduced by this code change:

- 164.312(b) (severity: block)
- 164.312(b) (severity: block)
- 164.312(d) (severity: block)
- 164.312(e)(1) (severity: block)
- 164.312(c)(1) (severity: block)

New Attack Surface

This new application feature allows users to upload files containing protected health information (PHI), introducing potential vulnerabilities through unencrypted data transmission and inadequate audit controls.

Critical and High Risks

Critical — Unauthorized access to PHI due to missing encryption, violating §164.312(a)(2)(iv).

High — Lack of audit controls enables malicious insiders to manipulate PHI without detection, violating §164.312(b).

High — Absence of authentication mechanisms allows unauthorized individuals to gain access to sensitive data, violating §164.312(d).

High — Unsecured file transfer exposes PHI during transit, violating §164.312(e)(1).

Medium — Inadequate integrity checks may lead to accidental or intentional alteration of PHI, violating §164.312(c)(1).

Recommended Mitigations

§164.312(a)(2)(iv): Implement end-to-end encryption for all PHI stored and transmitted within the system.

§164.312(b): Deploy comprehensive audit logs capturing all user activities related to PHI access and modification.

§164.312(d): Enforce strong authentication measures, such as multi-factor authentication, for all users accessing PHI.

§164.312(e)(1): Utilize secure protocols like HTTPS for transmitting PHI over networks.

§164.312(c)(1): Implement checksums or digital signatures to ensure data integrity during storage and transmission.

Aggregate Risk Level

The aggregate risk level is CRITICAL due to the presence of multiple critical risks involving unprotected PHI, including lack of encryption, absence of audit controls, weak authentication, and unsecured transmission. These factors collectively pose an extreme threat to patient privacy and regulatory compliance.

Test Evidence

Automated test results demonstrating compliance verification:


```
{
  "pr_number": 2,
  "test_suite": "HIPAA Compliance Test Suite",
  "test_results": {
    "encryption_at_rest": {
      "status": "FAILED",
      "failures": [
        {
          "model": "Diagnosis",
          "field": "diagnosis",
          "control_violated": "164.312(a)(2)(iv)"
        },
        {
          "model": "Diagnosis",
          "field": "icd10Code",
          "control_violated": "164.312(a)(2)(iv)"
        },
        {
          "model": "Diagnosis",
          "field": "notes",
          "control_violated": "164.312(a)(2)(iv)"
        }
      ]
    }
  },
  "summary": {
    "compliance_status": "NON_COMPLIANT"
  }
}
```

NPRM Forward-Compatibility Analysis

Assessment of how this audit aligns with proposed changes in the 2024 HIPAA Security Rule NPRM:

Under the 2024 HIPAA Security Rule NPRM (HHS OCR, RIN 0945-AA22, Jan. 6, 2025), §164.312(a)(2)(iv) is proposed to move from addressable to required. BobGuard already enforces the stricter standard.

164.312(a)(2)(iv): Encryption and Decryption (Addressable)

Existing Status: addressable

NPRM Proposal: would_become_required

BobGuard Action: Already enforces the stricter proposed standard.

164.312(a)(2)(iv): Encryption and Decryption (Addressable)

Existing Status: addressable

NPRM Proposal: would_become_required

BobGuard Action: Already enforces the stricter proposed standard.

164.312(a)(2)(iv): Encryption and Decryption (Addressable)

Existing Status: addressable

NPRM Proposal: would_become_required

BobGuard Action: Already enforces the stricter proposed standard.

164.312(a)(2)(iv): Encryption and Decryption (Addressable)

Existing Status: addressable

NPRM Proposal: would_become_required

BobGuard Action: Already enforces the stricter proposed standard.

Audit Sign-off

Auditor: BobGuard Compliance Officer

Governance Entry: pending

Governance Status: pending

Date: 2026-05-03

Digital Audit Trail

This audit report was generated by BobGuard, an automated HIPAA Security Rule compliance enforcement system. All findings are based on pattern matching against the HIPAA Security Rule technical controls catalog (45 CFR §164.308, §164.310, §164.312) and forward-compatible with the 2024 NPRM proposed changes.